Как защитить данные своего GitHub

GitHub не даёт отдельной настройки «ключи добавляет только такой-то человек». Это решается тем, кому доступны учётная запись и репозиторий.

Что важно понимать

- Git не проверяет автора коммита: имя и почта — это просто текст, который можно указать любой.
- GitHub при push проверяет только право на запись в репозиторий, а не совпадение автора коммита с тем, кто пушит.
- GitHub привязывает коммит к профилю по почте, поэтому коммит может отображаться от имени человека, который его не делал.

Личный аккаунт: основные шаги

1. **Защитить аккаунт.** Ключ к аккаунту может добавить любой, кто в него вошёл, поэтому нужны сильный пароль и 2FA, лучше через аппаратный ключ или приложение. Сторонние токены и OAuth-приложения с лишними правами стоит отозвать.
2. **Ограничить людей.** Deploy keys в личном репозитории добавляет только владелец. Коллабораторы ходят своими ключами через свои аккаунты, поэтому доступ определяется списком в Settings → Collaborators: оставьте там только одобренных людей.
3. **Проверить текущие ключи.** В Settings → SSH and GPG keys и в Deploy keys репозитория удалите всё незнакомое. Там же видно, когда ключ использовался в последний раз.

Централизованный контроль

Перенесите репозиторий в организацию. Там можно отключить deploy keys и назначать права по ролям, а на Enterprise Cloud ещё есть SAML SSO и SSH-сертификаты, которые выдаёт только ваш центр сертификации.

Защита ключа на машине

Всё перечисленное выше не остановит того, кто работает под пользователем с уже доступным ключом, в том числе автоматизированного агента. Чтобы каждый push требовал участия человека, нужно одно из двух:

- **Аппаратный ключ (лучший вариант).** Каждый push подтверждается касанием ключа. На удалённом сервере ключ должен быть проброшен с вашего компьютера через SSH-агент.

```
ssh-keygen -t ed25519-sk
```

- **Подтверждение через агент.** Каждое использование ключа подтверждается в диалоговом окне. Это слабее аппаратного ключа, и на сервере без графики нужна рабочая программа для запроса подтверждения.

```
ssh-add -c
```

Обычная парольная фраза помогает только без агента: когда ключ уже загружен в агент, она ничего не спрашивает.

Защита ветки main

- Правила защиты ветки ограничат даже тех, у кого есть SSH-доступ: обязательный PR с ревью и Require signed commits.
- Включите Do not allow bypassing, иначе администратор сможет обойти правила.
- Подписывайте коммиты GPG- или SSH-ключом: GitHub покажет метку Verified, а без ключа владельца такую подпись не получить.
- Для приватных репозиториев на бесплатном тарифе защита веток недоступна, нужен Pro.